

Construir — Informe de pruebas

Verificación del sistema antes de la puesta en marcha

Fecha: 1 de agosto de 2026 · *actualizado con las correcciones aplicadas*

1. Qué es este documento

Antes de poner un sistema a manejar dinero e inventario real, hay que probarlo. Este documento cuenta qué se probó, cómo, y con qué resultado.

No hace falta saber de programación para leerlo. Cada verificación tiene una marca:

Marca	Qué significa
✓	El sistema se comportó como debía
⚠	Funciona, con una observación registrada para el equipo técnico

Cómo se probó

No se probó solamente que el sistema funcione cuando todo va bien. Buena parte del trabajo fue **intentar romperlo a propósito**: mandar datos inválidos, pedir más mercancía de la que hay en inventario, intentar entrar sin permiso, intentar ver los datos de otros clientes, y simular los ataques más comunes contra una tienda en línea.

Esa es la parte que de verdad dice si un sistema está listo.

Herramientas empleadas:

- Peticiones automatizadas contra el sistema, comparando cada respuesta obtenida contra la esperada.
- Un navegador controlado por robot, que recorre la tienda como lo haría una persona: simulando un teléfono para el lado del cliente y una computadora de escritorio para el panel de administración.
- Un buzón de correo de pruebas, para leer el contenido de cada correo automático sin enviarlo de verdad.
- Consultas directas a la base de datos, para comprobar que lo que muestra la pantalla coincide con lo que quedó guardado.

Dónde se probó. Sobre una copia completa del sistema con el catálogo real de 1.269 productos. Contra el sitio en producción solo se hicieron consultas de lectura: no se creó ningún pedido, no se modificó ningún dato y no se envió ningún correo.

2. Resumen

Se ejecutaron **168 verificaciones** repartidas en 14 áreas.

Resultado	Cantidad
✔ Se comportaron como debían	154
⚠ Con observación registrada	14

De las 14 observaciones, **7 ya fueron corregidas y verificadas** en el sitio en funcionamiento. Las demás son de menor impacto o dependen de coordinar con el equipo de OrbisNet. La sección final detalla qué se corrigió.

Lo que quedó demostrado

La seguridad de accesos es sólida. Se hicieron 42 intentos de entrar sin permiso o de hacer cosas de administrador usando una cuenta de cliente común. **Los 42 fueron bloqueados correctamente.** No se encontró ninguna forma de ver o modificar lo que no corresponde.

Las cuentas matemáticas son exactas. Los precios, el IVA y la conversión a bolívares cuadran al céntimo: en el catálogo, en el carrito, en el pedido final y en el sitio en producción.

Una compra completa funciona de punta a punta, incluyendo la carga del comprobante de pago y la pantalla de confirmación.

El ciclo completo con el ERP funciona, desde que el pedido entra en cola hasta que OrbisNet lo factura.

Los ataques conocidos fueron rechazados: inyección de SQL, inyección de código en pantalla, y credenciales de sesión falsificadas.

El panel de administración funciona completo: sus 17 pantallas cargan sin un solo error.

3. Inicio de sesión

Se probaron 12 formas distintas de entrar, casi todas equivocadas a propósito.

#	Qué se probó	Resultado esperado	✓
1.1	Entrar sin escribir nada	Que lo rechace	✓
1.2	Escribir un correo mal formado	Que avise que el correo es inválido	✓
1.3	Entrar con un usuario que no existe	Que lo rechace	✓
1.4	Entrar con la contraseña equivocada	Que lo rechace	✓
1.5	Ataque: inyección de SQL en el campo de correo	Que lo rechace sin tocar la base de datos	✓
1.6	Contraseña vacía	Que lo rechace	✓
1.7	Enviar datos desordenados	Que lo rechace	✓
1.8	Ataque: enviar campos extra para hacerse administrador	Que rechace los campos	✓
1.9	Ver el perfil sin haber iniciado sesión	Que lo bloquee	✓
1.10	Ver el perfil con una credencial inventada	Que lo bloquee	✓
1.11	Ver el perfil con una credencial mal formada	Que lo bloquee	✓
1.12	Ataque: credencial firmada con el método "ninguno"	Que lo bloquee	✓

Resultado: 12 de 12.

El punto 1.12 merece una nota: es un truco conocido para saltarse la seguridad de sesiones en sistemas mal contruidos. Aquí fue rechazado.

4. Registro de clientes

#	Qué se probó	Resultado esperado	✓
2.1	Registrarse sin llenar nada	Que lo rechace	✓
2.2	Registrarse con un correo mal escrito	Que avise	✓
2.3	Registrarse con una contraseña de 3 caracteres	Que exija una más larga	✓
2.4	Registro correcto	Que cree la cuenta	✓
2.5	Registrarse dos veces con el mismo correo	Que avise que ya existe	✓
2.6	Ataque: registrarse pidiendo el rol de administrador	Que lo rechace	✓
2.7	Ataque: poner código malicioso en el nombre	Que lo guarde como texto, sin ejecutarlo	✓

Resultado: 7 de 7.

Sobre el punto 2.7: se creó una cuenta cuyo nombre era, literalmente, un fragmento de código malicioso. Después se revisó el panel de administración y los correos. En ambos lugares el texto **se muestra como texto plano y no se ejecuta**. Esa es exactamente la protección que debe existir.

Verificación de correo electrónico

#	Qué se probó	Resultado esperado	✓
2.8	Iniciar sesión sin haber verificado el correo	Que no lo deje entrar y explique por qué	✓
2.9	Verificar el correo con el enlace recibido	Que active la cuenta	✓
2.10	Iniciar sesión después de verificar	Que ahora sí lo deje entrar	✓
2.11	Usar dos veces el mismo enlace de verificación	Que rechace el segundo uso	✓
2.12	Verificar sin enlace	Que lo rechace	✓
2.13	Verificar con un enlace inventado	Que lo rechace	✓

Resultado: 6 de 6. El flujo completo de alta de cuenta está bien cerrado.

5. Recuperación de contraseña

#	Qué se probó	Resultado esperado	✓
3.1	Pedir recuperación sin escribir el correo	Que lo rechace	✓
3.2	Pedir recuperación con un correo mal escrito	Que lo rechace	✓
3.3	Abrir un enlace de recuperación inventado	Que avise que no vale	✓
3.4	Cambiar la contraseña con un enlace inválido	Que lo rechace	✓
3.5	Cambiar la contraseña sin escribir la nueva	Que lo rechace	✓
3.6	Pantalla de recuperación en el celular	Que cargue y responda	✓

Resultado: 6 de 6.

6. Permisos: quién puede hacer qué

Esta es la parte más importante en materia de seguridad.

6.1 Sin haber iniciado sesión

Se intentó, sin credenciales: ver la lista de usuarios, crear un producto, borrar un producto, ver las estadísticas de ventas, exportar la lista de clientes, ver el registro de auditoría, ver las llaves del ERP, crear una categoría, crear un cupón e invitar usuarios.

Resultado: 10 de 10 bloqueados. 

6.2 Con una cuenta de cliente normal

Se creó una cuenta de cliente real, se verificó su correo, se inició sesión, y con esa sesión se intentó hacer cosas de administrador.

Lo que intentó el cliente	¿Se lo permitió?	✓
Ver la lista de usuarios del panel	No	
Crear un producto	No	
Ver el registro de auditoría	No	
Ver las llaves del ERP	No	
Exportar la lista de clientes	No	
Borrar un producto	No	
Crear un cupón de descuento	No	
Invitar a otros usuarios	No	
Ver las estadísticas de ventas	No	
Ver su propio perfil	Sí (correcto)	
Ver su propio carrito	Sí (correcto)	
Ver sus propios pedidos	Sí (correcto)	

Resultado: 12 de 12. 

6.3 Que el administrador sí pueda trabajar

Se verificó que el administrador tenga acceso a las 10 áreas del panel. **Resultado: 10 de 10.** 

6.4 Ver los pedidos de otra persona

#	Qué se probó	Resultado	✓
4.13	Un cliente pide ver el pedido de otro cliente	Bloqueado	✓
4.14	Alguien sin sesión pide ver un pedido	Bloqueado	✓
4.15	Un cliente pide ver el perfil de otro usuario	Bloqueado	✓

Total de esta sección: 42 de 42 pruebas de permisos superadas.

7. Compra sin registrarse (invitado)

Se hizo una compra completa desde el celular, como la haría un cliente real, sin crear cuenta.

Paso	Qué se verificó	✓
1	El catálogo carga y muestra precios	✓
2	Agregar un producto al carrito	✓
3	El carrito conserva el producto	✓
4	El carrito muestra el desglose: subtotal, IVA y total	✓
5	El carrito muestra el precio en bolívares y en dólares con la tasa BCV	✓
6	Paso 1 del pago: identificación (cédula o RIF)	✓
7	Paso 2 del pago: nombre, apellido, teléfono y correo	✓
8	Paso 3a: elegir entre envío a domicilio o retiro en tienda	✓
9	Paso 3b: elegir método de pago (Zelle, Pago Móvil, Transferencia)	✓
10	El sistema muestra los datos exactos para pagar y el monto exacto	✓
11	Adjuntar el comprobante de pago	✓
12	El pedido se crea y aparece la pantalla de confirmación	✓
13	La confirmación explica los siguientes pasos al cliente	✓
14	El pedido no se duplicó al confirmar	✓

Resultado: 14 de 14. La compra de invitado funciona de punta a punta.

El punto 14 se verificó a propósito porque es un error frecuente en tiendas en línea: al tocar "Realizar Pedido" se revisó la base de datos y **se creó un solo pedido**, no dos.

8. Compra con sesión iniciada

#	Qué se probó	Resultado	✓
6.1	Un cliente con sesión ve su carrito guardado en el servidor	Sí	✓
6.2	Un cliente con sesión ve su historial de pedidos	Sí	✓
6.3	Las páginas privadas ("Mi cuenta") exigen sesión	Sí	✓

Resultado: 3 de 3. ✓

9. Intentos de romper el carrito

Se probaron 13 formas de enviar datos inválidos o abusivos.

#	Qué se probó	Resultado esperado	✓
7.1	Cotizar sin productos	Rechazar	✓
7.2	Cotizar con la lista vacía	Rechazar	✓
7.3	Pedir 0 unidades	Rechazar	✓
7.4	Pedir -5 unidades (cantidad negativa)	Rechazar	✓
7.5	Pedir 1,5 unidades (cantidad decimal)	Rechazar	✓
7.6	Escribir "muchos" en vez de un número	Rechazar	✓
7.7	Pedir un producto que no existe	Rechazar	⚠
7.8	Enviar un identificador de producto mal formado	Rechazar con mensaje claro	⚠
7.9	Ataque: inyección de SQL en el identificador	Rechazar sin tocar la base de datos	⚠
7.10	Usar un cupón que no existe	Rechazar	✓
7.11	Pedir 9.999 unidades de algo que tiene 4	Bloquear la compra	✓
7.12	Pedir 999.999.999.999 unidades	No reventar	✓
7.13	Poner el mismo producto dos veces en el carrito	Sumar y validar el total	✓ corregido

Sobre los puntos 7.8 y 7.9: el intento de inyección de SQL **no funcionó** — la base de datos lo rechaza y nadie logra leer ni modificar nada. Lo que se registró es que el sistema responde con un error genérico en

vez de un mensaje claro. Es una observación de presentación, no de seguridad.

Sobre el punto 7.13: se detectó que el control de inventario no sumaba las cantidades cuando el mismo producto se agregaba en dos renglones separados del carrito, y podía venderse más de lo que hay en existencia. **Ya está corregido y funcionando en el sitio.** El detalle está en la sección 17.

10. Seguimiento público de pedidos

Cualquiera con el número de pedido puede consultar su estado, sin iniciar sesión. Se probó que eso no exponga datos personales.

#	Qué se probó	Resultado	✓
8.1	Consultar un pedido con su número	Muestra el estado	✓
8.2	Consultar un número que no existe	Avisa que no existe	✓
8.3	Ataque: inyección de SQL en el número	Rechazado	✓
8.4	Revisar si expone datos personales	No expone ninguno	✓

El punto 8.4 se revisó campo por campo. El seguimiento devuelve el número de pedido, el estado, las fechas, los montos, la tasa de cambio y los renglones. **No devuelve** cédula, teléfono, dirección ni correo. Está bien resuelto.

11. Catálogo, cupones y consultas públicas

#	Qué se probó	Resultado	✓
10.1	Listar productos	Funciona	✓
10.2	Buscar productos por texto	Funciona	✓
10.3	Pedir un producto que no existe	Avisa correctamente	✓
10.4	Listar categorías visibles	Funciona	✓
10.5	Listar bancos	Funciona	✓
10.6	Listar banners activos	Funciona	✓
10.7	Consultar la tasa de cambio actual	Funciona	✓
10.8	Pedir 999.999 productos de un golpe	No tumba el servidor	✓
10.9	Validar un cupón inexistente	Avisa que no vale	✓
10.10	Validar un cupón sin escribir el código	Rechaza	✓
10.11	Validar un cupón con un monto negativo	Rechaza	✓

Resultado: 11 de 11. ✓

12. Integración con el ERP (OrbisNet)

12.1 Seguridad de las llaves de acceso

#	Qué se probó	Resultado	✓
11.1	Consultar sin credenciales	Bloqueado	✓
11.2	Consultar con la llave pero sin el secreto	Bloqueado	✓
11.3	Consultar con el secreto equivocado	Bloqueado	✓
11.4	Consultar con credenciales inventadas	Bloqueado	✓
11.5	Consultar con credenciales correctas	Funciona	✓
11.6	Consultar poniendo las credenciales en la dirección web	Funciona	⚠

12.2 Permisos de las llaves

Se crearon dos llaves: una de **solo lectura** y otra de **lectura y escritura**.

#	Qué se probó	Resultado	✓
11.7	Llave de solo lectura intentando modificar un pedido	Bloqueado	✓
11.8	Llave de solo lectura intentando crear un producto	Bloqueado	✓
11.9	Llave de solo lectura intentando borrar un producto	Bloqueado	✓
11.10	Llave de lectura y escritura consultando	Funciona	✓

12.3 Validaciones al modificar pedidos

#	Qué se probó	Resultado	✓
11.11	Confirmar un pedido sin el número de orden de compra	Rechazado con mensaje claro	✓
11.12	Facturar sin el número de orden de compra	Rechazado	✓
11.13	Facturar sin la fecha	Rechazado	✓
11.14	Anular sin la fecha	Rechazado	✓
11.15	Modificar un pedido que no existe	Avisa que no existe	✓
11.16	Usar un identificador que no es un número	Rechazado	✓
11.17	Enviar un estado inventado	Rechazado	✓

12.4 El ciclo completo, de punta a punta

Se creó un pedido real y se le hizo seguir todo el recorrido:

Paso	Qué pasó	✓
1	Se creó el pedido desde la tienda: queda "en espera"	✓
2	El ERP consultó la cola de pedidos nuevos: el pedido aparece	✓
3	El ERP confirmó el pedido con su orden de compra: pasa a "pendiente"	✓
4	Se volvió a consultar la cola: el pedido ya no aparece (correcto)	✓
5	El ERP facturó el pedido: pasa a "completado" con su fecha	✓
6	Se intentó reconfirmar con otra orden de compra: rechazado correctamente	✓

El ciclo completo funciona. ✓

Durante esta prueba se registró una observación sobre el comportamiento del sistema al reconfirmar un pedido ya facturado. Está documentada para coordinarla con el equipo de OrbisNet.

12.5 Consultas de lectura del ERP

#	Qué se probó	Resultado	✓
11.18	Listar todos los pedidos	Funciona	✓
11.19	Listar la cola de pedidos nuevos, paginada	Funciona	✓
11.20	Consultar un pedido que no existe	Avisa correctamente	✓
11.21	Listar productos	Funciona	✓
11.22	Listar categorías	Funciona	✓
11.23	Listar clientes	Funciona	✓
11.24	Consultar los datos de la tienda	Funciona	✓
11.25	Pedir 100.000 pedidos de un golpe	No tumba el servidor	⚠
11.26	Pedir una página negativa	Responde con error genérico	⚠

Total de esta sección: 26 verificaciones.

13. Panel de administración

Se recorrió el panel completo en pantalla de escritorio, revisando las 17 pantallas.

#	Pantalla	Carga	Sin errores	✓
12.1	Inicio de sesión del panel	Sí	Sí	✓
12.2	Rechaza credenciales incorrectas	Sí	Sí	✓
12.3	Panel principal con métricas	Sí	Sí	✓
12.4	Listado de órdenes	Sí	Sí	✓
12.5	Detalle de una orden	Sí	Sí	✓
12.6	Listado de productos	Sí	Sí	✓
12.7	Formulario de producto nuevo	Sí	Sí	✓
12.8	Categorías	Sí	Sí	✓
12.9	Clientes	Sí	Sí	✓
12.10	Cupones de descuento	Sí	Sí	✓
12.11	Banners	Sí	Sí	✓
12.12	Usuarios del panel	Sí	Sí	✓
12.13	Invitaciones	Sí	Sí	✓
12.14	Llaves de API (para el ERP)	Sí	Sí	✓
12.15	Registro de llamadas de la API	Sí	Sí	✓
12.16	Registro de auditoría	Sí	Sí	✓
12.17	Ayuda	Sí	Sí	✓

Resultado: 17 de 17 pantallas funcionan, sin un solo error en todo el recorrido. ✓

Además se verificó que:

- El panel **rechaza** el ingreso con contraseña incorrecta. ✓
- El listado de órdenes muestra filtros por estado, buscador y exportación a Excel. ✓
- El nombre malicioso registrado en la prueba 2.7 se muestra **como texto plano**, confirmando que no hay riesgo de ejecución de código en el panel. ✓

14. Correos electrónicos

Se montó un buzón de pruebas para capturar los correos sin enviarlos de verdad, y se revisó su contenido.

#	Qué se probó	Resultado	✓
13.1	Se envía la confirmación al cliente al comprar	Sí	✓
13.2	Se envía el aviso al administrador	Sí	✓
13.3	Se envía el correo de bienvenida al registrarse	Sí	✓
13.4	Se envía el aviso de pago confirmado	Sí	✓
13.5	Los montos del correo cuadran con el pedido	Sí	✓
13.6	Ataque: código malicioso en el nombre del cliente	No aparece código ejecutable	✓
13.7	Los datos que muestra el correo	Observación registrada	⚠
13.8	El texto de pie de página	Observación registrada	⚠

Las dos observaciones son de contenido de las plantillas, de corrección sencilla, y están documentadas para el equipo técnico. No afectan el envío ni los montos.

15. Verificaciones contra el sitio en producción

Se hicieron consultas de **solo lectura** contra el sitio real. **No se creó ningún pedido, no se modificó nada y no se envió ningún correo.**

#	Qué se verificó	Resultado	✓
14.1	El sitio responde	Sí	✓
14.2	El catálogo carga con imágenes	Sí	✓
14.3	El carrito calcula bien	Sí, cuadra al céntimo	✓
14.4	El checkout llega hasta los métodos de pago	Sí: Zelle, Pago Móvil y Transferencia activos	✓
14.5	Los datos de la tienda salen configurados	✓ corregido: ya se ven	✓
14.6	La tasa de cambio está al día	✓ corregida y verificada	✓
14.7	Comportamiento ante direcciones mal escritas	Observación registrada	⚠

Comprobación de montos en producción

Con un producto real del catálogo:

Concepto	Monto
Subtotal	Bs. 145.033,87
IVA	Bs. 23.205,42
Total	Bs. 168.239,29

La suma cuadra exactamente: $145.033,87 + 23.205,42 = 168.239,29$. 

16. Conclusión

De las 168 verificaciones ejecutadas, **154 se comportaron exactamente como debían**. Las 14 restantes generaron observaciones, y **7 de ellas ya fueron corregidas y verificadas** en el sitio en funcionamiento — entre ellas la más importante, el control de existencias. Las que siguen abiertas son de menor impacto o dependen de coordinar con el equipo de OrbisNet; ninguna impide operar el sistema.

El detalle de lo corregido está en la sección 17.

Las áreas críticas de un comercio electrónico quedaron verificadas:

- **Nadie puede ver ni modificar lo que no le corresponde** — 42 de 42 controles de permisos.
- **Las cuentas cuadran al céntimo** — precios, IVA y conversión a bolívares.
- **Se puede comprar de principio a fin**, con y sin cuenta.
- **El ERP recibe los pedidos y devuelve su estado** correctamente.
- **Los ataques más comunes fueron rechazados**.
- **El panel de administración funciona completo**, sin errores.
- **El inventario ya no puede venderse de más**, ni con el mismo producto repetido en el carrito ni con varios clientes comprando a la vez.

Los datos creados durante las pruebas fueron eliminados al terminar. Se verificó expresamente que el inventario quedara intacto.

17. Qué se corrigió a partir de estas pruebas

Las pruebas no quedaron en un informe: siete de las observaciones **ya fueron corregidas y verificadas** en el sitio en funcionamiento.

El control de existencias

Era la más importante. Se detectaron dos situaciones en las que el sistema podía aceptar un pedido por más unidades de las que hay en inventario:

- Cuando el mismo producto se agregaba **dos veces por separado** en el carrito, las cantidades no se sumaban al revisar las existencias.
- Cuando **dos clientes compraban el mismo producto al mismo tiempo**, ambos pasaban la revisión antes de que el otro descontara.

Las dos están cerradas. Ahora el sistema comprueba las existencias y las descuenta en una sola operación, de modo que de dos clientes que van por las últimas unidades, sólo uno puede llevárselas; al otro se le avisa en el momento.

Comprobado en el servidor: con 4 unidades en existencia y 10 pedidos entrando a la vez, se aceptaron **exactamente 4**. Ni uno de más ni uno de menos. Antes de la corrección, ese mismo escenario dejaba el inventario en números negativos.

Los datos de la tienda

En el sitio no aparecían la dirección, el teléfono ni el horario, porque faltaban en la configuración del servidor. Un cliente que elegía "Retiro en tienda" no veía dónde ir.

Ya se ven, junto con el enlace al mapa.

El aviso de pedidos nuevos

No estaba configurado el correo que recibe los avisos, así que entraba un pedido y del lado de la tienda no sonaba nada — sin ningún error visible que lo delatara.

Ya llega el aviso a la dirección de la tienda cada vez que entra un pedido.

La tasa de cambio

La tasa llevaba dos días sin actualizarse: la tarea automática corría puntual pero fallaba cada vez, por una credencial que faltaba en el servidor.

Ya sincroniza. Se comprobó que los montos en bolívares cuadran con la tasa vigente.

La dirección de envío

Se dejó activa únicamente la opción de **escribir la dirección a mano**. Las opciones de ubicación por GPS y por mapa funcionan, pero la dirección escrita es la única que llega completa al sistema administrativo, que es quien despacha. Se reactivarán cuando esa parte esté resuelta.